

Цель работы: развернуть *Nginx* для веб-приложения и применить бестпрактис в конфигурации.

Теоретическая справка

Прокси (forward proxy) — это промежуточный сервер между клиентом и интернетом. *Обратный прокси (reverse proxy)* стоит перед серверами и принимает входящий трафик от клиентов.

Балансировка — это распределение входящих запросов между несколькими серверами

LibreSpeed — это открытое веб-приложение для измерения скорости интернет-соединения. В данной лабораторной работе используется Node.js-версия, где серверная часть запускается на нескольких портах (например, 8888, 8889, 8890).

DoS (Denial of Service) — атака с одного источника, направленная на исчерпание ресурсов сервера. *DDoS* — распределённая атака, идущая с множества источников (часто ботнета).

Slowloris — это тип *DoS*-атаки на веб-сервер со следующей концепцией:

1. Клиент открывает соединение.
2. Начинает отправлять HTTP-заголовки.
3. Делает это очень медленно, по частям.
4. Соединение остаётся открытым.
5. Таких соединений открывается очень много и ресурсы сервера исчерпаются.

Разница 4 и 7 уровня OSI в разрезе Nginx:

- L4 (транспортный уровень) — работа с TCP/UDP как с потоком байт. Nginx в этом режиме просто проксирует соединение и подробно не анализирует трафик.
- L7 (прикладной уровень) — анализирует сам протокол. Nginx может смотреть заголовки, URI, куки, делать маршрутизацию по домену, пути, методам, кешировать и так далее.

Порядок выполнения работы



Экономьте грант

Выключайте виртуальную машину в случае перерыва в выполнении работы или после завершения.

Подготовка

```
sudo apt update
sudo apt install -y nginx nodejs npm git nload
sudo mkdir -p /opt/librespeed
sudo chown $USER:$USER /opt/librespeed
cd /opt/librespeed
git clone -b node https://github.com/librespeed/speedtest.git
cd speedtest/src
npm install
```

В файле `SpeedTest.js` последние три строчки замените на:

```
const PORT = process.argv[2] || 8888;
Server.listen(PORT, '127.0.0.1', function () {
  console.log(`Speedtest Server is up and running on ${PORT}!`);
});
```

В конец файла добавьте:

```
Server.get('/whoami', function (req, res) {
  res.json({
    port: PORT,
    pid: process.pid
  });
});
```

Запустите инстансы приложения `node SpeedTest.js 8890 & node SpeedTest.js 8889 & node SpeedTest.js 8888 &` (требуется перезапустить после включения ВМ или написать юнит).

Написание конфигурации

Ваша задача в директории `/etc/nginx/sites-available` написать конфиг `librespeed.conf` используя теорию, рассказанную на лекции. Сделайте символическую ссылку в `/etc/nginx/sites-enabled`.

Требования:

- В `server_name` используйте доменное имя DuckDNS из прошлой лабораторной работы.
- `root /opt/librespeed/speedtest/src/public;`
- Бэкенды — `127.0.0.1:8888, 127.0.0.1:8889, 127.0.0.1:8890`
- Разрешенные методы — POST, GET.
- Используйте заголовки безопасности.
- Редиректите 80 порт на 443.
- Блокируйте роботов `msnbot` и `scrapbot` и менеджеры загрузки.
- Уберите упоминание Nginx из заголовков.
- Защититесь от переполнения буфера.
- Запретите обращение к сайту по IP.
- Не меняйте ничего в `/etc/nginx/nginx.conf`.
- После создания файла конфига настройте использование сертификата Let's Encrypt по инструкции <https://certbot.eff.org/instructions?ws=nginx&os=pip>. Он сам внесет изменения в файл.

Тюнинг SSL

Certbot по умолчанию применил бестпрактис настроек SSL — выключил SSL первой версии, указал конкретные алгоритмы шифрования и тому подобное. В энтерпрайзе вам потребуется указывать это вручную.

Перезапустите nginx `sudo systemctl reload nginx` и проверьте работу сайта. По эндпоинту `/whoami` вы можете смотреть на какой инстанс вы попали.

Организуем DOS атаку

Дисклеймер

Информация, представленная ниже, предназначена исключительно для образовательных целей и использования в рамках легальных тестов конфигурации. В рамках лабораторной работы вы организуете DOS атаку на собственную виртуальную машину. Организация подобных атак на чужие ресурсы в Российской Федерации влечет уголовную ответственность.

Ваша задача добавить в конфиг настройки для защиты от Slowloris атаки.

Для проверки на своем компьютере склонируйте репозиторий <https://github.com/gkbrk/slowloris> и выполните `python3 slowloris.py (ваш домен duckdns) --https -p 443 -ua -v -s (число близкое к значению ulimit -n)`.

На виртуальной машине наблюдайте приход трафика: посмотрите график `nload`, выполните `ss -ant | grep :443` и посмотрите количество ESTAB-соединений. Для мониторинга количества соединений выполните `watch 'ss -ant | grep :443 | wc -l'`.

Критерием подверженности атаки будут сообщения вида `worker connections not enough` или иное схожее в `tail -f /var/log/nginx/error.log` спустя некоторое время работы скрипта. Соответственно, неподверженность атаки — это отсутствие подобных ошибок.

Зависимость от обстоятельств

Скрипт может довольно медленно открывать новые сокеты из-за особенности Wi-Fi сети. Возможно, у вас не получится организовать данную атаку с публичной или мобильной сети из-за особых настроек, поэтому лучше использовать домашний Wi-Fi. Если не получается со всех видов сетей, обратитесь в чат.

Вопросы

1. Зачем нужна балансировка?
2. Убейте процессы бэкендов и откройте сайт. Что произошло и как вы это объясните?
3. Запись `Server.listen(PORT, '127.0.0.1')` означает, что мы слушаем только с адреса 127.0.0.1, почему не указать 0.0.0.0?
4. Почему slowloris-атака бьёт по пулам соединения, а не CPU?
5. Почему использовали Nginx в седьмом уровне?
6. Почему не отразить slowloris-атаку просто увеличив количество воркеров?

Понятийный минимум

1. Nginx (что такое, сценарии использования).
2. Балансировка. Методы.
3. Nginx в 4 и 7 уровнях OSI.
4. Slowloris-атака.
5. Этапы установки соединения в Linux.